

SYSTEM AND ORGANIZATION CONTROLS 2 (SOC 2) REPORT

*Report on OrbitClear Technologies Ltd's Description of its Post-Trade Processing System and on the Suitability of the Design and Operating Effectiveness of its Controls Relevant to **Security, Availability and Confidentiality***

Type 2 Examination Report

Reporting period: 1 January 2025 through 30 June 2025

Issued pursuant to AICPA AT-C Sections 105 and 205 and the 2017 Trust Services Criteria (TSP Section 100A).

Independent Service Auditor: **Marlow & Vance LLP**, Chartered Accountants (Ireland)

Report date: 14 August 2025

Report reference: MV-SOC2-OBC-2025-01

Confidential — For the use of OrbitClear Technologies Ltd, its customers, and the regulators and independent auditors of its customers.

Table of Contents

Section	Title	Page
I	Independent Service Auditor's Report	3
II	Management of OrbitClear Technologies Ltd's Assertion	5
III	Description of OrbitClear's Post-Trade Processing System	6
IV	Trust Services Criteria, Controls, and Tests of Controls	11

SECTION I

Independent Service Auditor's Report

To the Management of OrbitClear Technologies Ltd:

Scope

We have examined OrbitClear Technologies Ltd's ("OrbitClear" or the "Service Organization") accompanying description in Section III of its Post-Trade Processing System ("the System") throughout the period **1 January 2025 through 30 June 2025** (the "Reporting Period"), based on the criteria for a description of a service organization's system in DC Section 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report (AICPA, Description Criteria), and the suitability of the design and operating effectiveness of controls stated in the description throughout the period 1 January 2025 through 30 June 2025 to provide reasonable assurance that OrbitClear's service commitments and system requirements were achieved based on the trust services criteria relevant to **security, availability and confidentiality** (the "applicable trust services criteria") set forth in TSP Section 100A, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria).

This is OrbitClear's first Type 2 examination report. The Reporting Period is abbreviated (six months rather than the customary twelve months) to align the first post-examination reporting cycle with OrbitClear's fiscal calendar. A full twelve-month Type 2 examination will be performed for the period 1 July 2025 through 30 June 2026.

Service Organization's Use of a Subservice Organization

OrbitClear uses a subservice organization, **Nexus Identity Services LLC** (incorporated in Colorado, United States), to provide step-up multi-factor authentication factor-issuance and factor-verification services to end-users of the OrbitClear Post-Trade Processing System.

The description indicates that complementary subservice organization controls ("CSOCs") that are suitably designed and operating effectively are necessary, along with controls at OrbitClear, to achieve OrbitClear's service commitments and system requirements based on the applicable trust services criteria. **The description presents OrbitClear's controls and the types of CSOCs assumed in the design of OrbitClear's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by Nexus Identity Services LLC, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.** ("Carve-out method", per DC Section 200, paragraph 28.)

Service Organization's Responsibilities

OrbitClear is responsible for its service commitments and system requirements; the design, implementation and operating effectiveness of controls to provide reasonable assurance that its service commitments and system requirements were achieved; and the preparation and fair presentation of the description.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of the design and operating effectiveness of controls stated in the description, based on our examination. We conducted our examination in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, the description is fairly presented and the controls were suitably designed and operating effectively to achieve OrbitClear's service commitments and system requirements based on the applicable trust services criteria.

Inherent Limitations

Because of their nature and inherent limitations, controls at a service organization may not always operate effectively to achieve the service organization's service commitments and system requirements based on the applicable trust services criteria. Projections of any evaluation of effectiveness to future periods are subject to the risk that controls may become inadequate because of changes in conditions, or that the degree of compliance with the policies or procedures may deteriorate.

Basis for Qualified Opinion

As described in our tests of controls in Section IV of this report, exceptions were noted in relation to control activity AC-04 (enforcement of multi-factor authentication on privileged production accounts) and control activity VM-02 (remediation of critical infrastructure vulnerabilities within the time period specified by management's policy). Accordingly, the controls were not operating effectively throughout the Reporting Period to meet the relevant criteria in all material respects.

Qualified Opinion

In our opinion, except for the matters referred to in the preceding paragraph, in all material respects:

- the description fairly presents the System that was designed and implemented throughout the period 1 January 2025 through 30 June 2025;
- the controls stated in the description were suitably designed throughout the period 1 January 2025 through 30 June 2025 to provide reasonable assurance that OrbitClear's service commitments and system requirements would be achieved based on the applicable trust services criteria, if the controls operated effectively throughout that period and if user entities and the subservice organization applied the complementary controls assumed in the design of OrbitClear's controls throughout that period; and
- the controls stated in the description operated effectively throughout the period 1 January 2025 through 30 June 2025 to provide reasonable assurance that OrbitClear's service commitments and system requirements were achieved based on the applicable trust services criteria, if the complementary user entity controls and complementary subservice organization controls assumed in the design of OrbitClear's controls operated effectively throughout that period.

Marlow & Vance LLP
Chartered Accountants
Dublin, Ireland
14 August 2025

SECTION II

Management of OrbitClear Technologies Ltd's Assertion

We have prepared the accompanying description of OrbitClear Technologies Ltd's Post-Trade Processing System throughout the period 1 January 2025 through 30 June 2025 (the "description") based on the criteria for a description of a service organization's system in DC Section 200. The description is intended to provide report users with information about the System that may be useful when assessing the risks arising from interactions with OrbitClear's System, particularly information about system controls that OrbitClear has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the 2017 trust services criteria for security, availability and confidentiality.

We confirm, to the best of our knowledge and belief, that: (i) the description fairly presents the System that was designed and implemented throughout the period; (ii) the controls stated in the description were suitably designed and operating effectively throughout the period, except for the matters disclosed in the service auditor's report; and (iii) the information is presented in accordance with the description criteria.

Siobhán Reilly

Head of Information Security & Compliance
OrbitClear Technologies Ltd
8 August 2025

SECTION III

Description of OrbitClear's Post-Trade Processing System

A. Company Overview

OrbitClear Technologies Ltd ("OrbitClear") is a software-as-a-service provider of post-trade processing, matching, affirmation, reconciliation and regulatory transaction-reporting capabilities, headquartered in Dublin, Ireland. OrbitClear provides services to global and regional financial institutions, including investment banks, asset managers and broker-dealers.

B. Services Provided

- Real-time trade capture (FIX 4.4, FpML 5.x) and normalisation.
- Central matching, allocation and affirmation against counterparty and custodian confirmations.
- General-ledger and sub-ledger reconciliation (stock record, cash nostro).
- Break management and exception workflow with case tracking.
- Transaction reporting adapter (EMIR REFIT, MiFIR, CFTC Parts 43/45, MAS 610, HKMA SPM OR-1).

C. Principal Service Commitments and System Requirements

Service commitments to user entities, documented in the Master Services Agreement and Service Description Schedule, include:

- 24x7 availability of the production service with contractual uptime of 99.95% measured monthly.
- Confidentiality of customer data through encryption in transit and at rest and role-based access control.
- Segregation of customer data between user entities.
- Commitment not to transfer customer data outside the European Economic Area, other than (i) as required by applicable law, or (ii) for long-term immutable archival storage disclosed to user entities in the Service Description.

D. Components of the System

Infrastructure

The System operates within Amazon Web Services (AWS). Production workloads are hosted in the **eu-west-1 (Dublin)** Region as primary and the **eu-central-1 (Frankfurt)** Region as active-standby, with synchronous cross-region replication of the primary transactional database cluster (Amazon Aurora PostgreSQL). Immutable archive storage is used to retain regulatory records for the statutory retention period; details of archive configuration are set out in OrbitClear's *Business Continuity and Disaster Recovery Policy*.

Software

The System comprises approximately 84 micro-services written primarily in Go and Kotlin, deployed to Amazon EKS (Kubernetes) with an Istio service mesh. Amazon Aurora PostgreSQL provides the primary transactional store; Amazon S3 provides object storage; Amazon OpenSearch provides search.

People

As at 30 June 2025 OrbitClear employed 624 people across Ireland (354), the United Kingdom (91), Singapore (58) and India (121). Security, SRE and Platform functions are based primarily in Ireland and the United Kingdom.

Procedures

Policies and procedures are maintained under the authority of the Chief Information Security Officer and reviewed annually by the Management Risk Committee. Relevant policies include the Information Security Policy, Business Continuity and Disaster Recovery Policy, and Third-Party Risk Management Policy.

Data

Customer data transmitted to OrbitClear comprises trade economics (notional, rate, instrument identifier, counterparty LEI), standing settlement instructions, counterparty static data, and personal data of user-entity employees acting as named users. Transaction reports submitted to Approved Reporting Mechanisms and Trade Repositories are retained in an immutable archive for the statutory retention period.

E. Subservice Organizations

OrbitClear uses the following subservice organizations. The carve-out method is applied to each:

Subservice organization	Services provided	Method
Amazon Web Services, Inc. (Ireland)	Infrastructure hosting (eu-west-1 Dublin primary; eu-central-1 Frankfurt active-standby); object storage; managed database; KMS.	Carve-out
Okta, Inc.	Workforce identity provider for OrbitClear employees.	Carve-out
Datadog EU S.à r.l.	Platform observability, log retention (EU region).	Carve-out
Nexus Identity Services LLC	Step-up multi-factor authentication factor issuance and verification (push authenticator) for end-users of the OrbitClear Post-Trade Processing System	Carve-out

F. Complementary Subservice Organization Controls (CSOCs)

OrbitClear's controls, in combination with complementary subservice organization controls ('CSOCs'), are designed to provide reasonable assurance that the service commitments and system requirements are met. The following CSOCs are assumed to be in place at the relevant subservice organization:

Subservice	CSOC
AWS (Ireland)	Physical and environmental controls at AWS data centres; logical separation of customer tenants; hypervisor controls.
Okta	Authentication of OrbitClear workforce; credential protection.
Datadog EU	Protection of log data in transit and at rest within the EU region.
Nexus Identity Services LLC	(i) Issuance, binding and revocation of MFA factors to the correct end-user; (ii) protection of MFA factor secrets; (iii) revocation of MFA factors within 24 hours of user-termination notification from OrbitClear; (iv) logging of authentication and factor-verification events and provision of such logs to OrbitClear on request.

G. Complementary User Entity Controls (CUECs)

User entities are responsible for:

- Provisioning and de-provisioning their own end-users in the OrbitClear administration console and for promptly notifying OrbitClear of terminations via the federated identity provider.
- Safeguarding credentials and MFA factors issued to their named users.
- Review of access rights at a frequency commensurate with the user entity's own policies.
- Validation of trade and settlement data submitted to the System and reconciliation to the user entity's books and records.

SECTION IV

Trust Services Criteria, Controls, and Tests of Controls

This Section presents the controls stated by management to meet the applicable trust services criteria, the procedures performed by the service auditor to test the design and operating effectiveness of those controls, and the results of those procedures.

Symbol	Meaning
NE	No exceptions noted
E	Exceptions noted — see Test Result column for details

CC1 — Control Environment

Control ID	Control Description	Test Performed	Result
CC1.1	The Board and senior management have established, through the Code of Conduct and Information Security Policy, a tone that emphasises integrity and ethical behaviour.	Inspected the Code of Conduct and Information Security Policy; inspected the Board Risk Committee minutes for the Reporting Period; confirmed sign-off by CEO and CISO.	NE
CC1.4	A CISO is appointed and reports to the Chief Risk Officer, with direct access to the Board Risk Committee.	Inspected CISO appointment letter; observed CISO's attendance at the March 2025 Board Risk Committee.	NE

CC6 — Logical and Physical Access Controls

Control ID	Control Description	Test Performed	Result
AC-01	User access provisioning and de-provisioning is initiated through a ServiceNow request and approved by line manager and system owner prior to access being granted.	For a sample of 25 joiners and 25 leavers during the Reporting Period, inspected the ServiceNow ticket and approvals and confirmed agreement with Active Directory and CyberArk membership.	NE
AC-02	Access for terminated workforce members is removed within 4 business hours of HR leaver notification.	For a sample of 25 leavers, compared HR leaver date to Active Directory disable timestamp.	NE
AC-03	Privileged production access is granted only through CyberArk, with session recording enabled and quarterly recertification.	Inspected CyberArk configuration; for a sample of 20 privileged sessions selected from the CyberArk activity log, inspected session recordings.	NE
AC-04	Multi-factor authentication is enforced for all production user accounts, including privileged, administrative and break-glass accounts. The MFA configuration is reviewed monthly.	For a population of 547 production user accounts active at a point in time within the Reporting Period, inspected the MFA enrolment status in Okta and in the federated identity configuration. For a sample of 40 privileged accounts, inspected the enrolment and authentication history for the Reporting Period.	E

Exception detail — AC-04: Of the sample of 40 privileged accounts, **3 accounts assigned to the Cloud Infrastructure team were observed without MFA enrolment for a period of 47 days, from 2 March 2025 to 18 April 2025.** Root-cause analysis performed by OrbitClear management attributed the gap to a change to the conditional-access policy on 28 February 2025 that inadvertently excluded a group membership pattern used for break-glass accounts. The conditional-access policy was corrected on 18 April 2025 and MFA was re-enrolled on all 3 accounts. A control enhancement (CE-2025-07) requiring pre-deployment peer review of conditional-access policy changes has been implemented. Authentication logs for the 47-day period were reviewed and no unauthorised activity was identified on the 3 accounts.

Control ID	Control Description	Test Performed	Result
AC-05	Privileged access is recertified quarterly and standard access semi-annually by the system owner.	Inspected recertification campaigns in SailPoint IdentityIQ for Q1 and Q2 2025. For a sample of 10 users, confirmed system-owner attestation.	NE
AC-06	Administrative access is reachable only through the zero-trust access service (Zscaler ZPA); direct internet administrative access is blocked by security group rules.	Inspected Zscaler ZPA policies and AWS security-group rules; performed an observation that direct administrative ports were not reachable from a test source outside the ZPA enclave.	NE

CC7 — System Operations and Change Management

Control ID	Control Description	Test Performed	Result
VM-01	Infrastructure vulnerability scans are performed continuously by Qualys VMDR. Container image scans (Snyk, Aqua Trivy) are performed on every build, blocking critical findings in CI.	Inspected Qualys and Snyk configuration; for a sample of 10 CI pipeline runs, observed enforcement.	NE
VM-02	Identified vulnerabilities are remediated within the SLA defined in the Information Security Policy §9: Critical (CVSS ≥ 9.0) within 14 calendar days; High (7.0–8.9) within 30 days; Medium within 60 days; Low within 90 days.	For a population of 312 critical and high vulnerability findings identified during the Reporting Period, selected a sample of 25 critical and 40 high findings. For each, compared the first-detected date to the remediation-confirmed date and to the Information Security Policy SLA.	E

Exception detail — VM-02: Of the 25 critical findings sampled, **the mean time-to-remediate (MTTR) was 38 calendar days. 9 of 25 critical findings (36%) were remediated outside the 14-day policy SLA;** of those, 4 were remediated between 15 and 30 days of detection and 5 were remediated between 31 and 72 days of detection. Management represents that variance from the SLA arises principally from production change-freeze windows (month-end, quarter-end, and the ECB monetary-policy silent period) during which deployments are restricted. Of the 40 high findings sampled, 3 (8%) were remediated outside the 30-day SLA; the mean MTTR for high findings was 21 days. A remediation enhancement plan (ERP-2025-04) has been approved by the Management Risk Committee, incorporating a hot-fix process for critical findings that does not require a standard change window.

Control ID	Control Description	Test Performed	Result
VM-03	An annual third-party penetration test of the customer-facing application is performed and high/critical findings tracked to closure.	Inspected the NCC Group engagement letter and report dated September 2024. Inspected JIRA tickets for all high/critical findings and confirmed closure.	NE
CH-01	Production changes are authorised, tested, and approved through a change-management workflow prior to deployment.	For a sample of 30 production changes during the Reporting Period, inspected the change ticket, peer-review evidence, CAB approval and deployment log.	NE

CC6.7 — Confidentiality: Encryption of Data in Transit and at Rest

Control ID	Control Description	Test Performed	Result
EN-01	Customer data in transit is protected using TLS 1.2 or higher with the Service Organization's approved cipher suite list.	Inspected load-balancer, API Gateway, and service-mesh configuration; independently scanned a sample of endpoints.	NE
EN-02	Customer data at rest is protected using AES-256 envelope encryption with keys managed in AWS KMS (HSM-backed).	Inspected KMS configuration and tag-based enforcement; inspected database encryption status and S3 default encryption policy.	NE
EN-03	Data encryption keys are rotated in accordance with the Information Security Policy and KMS configuration.	Inspected KMS configuration and key-rotation settings; inspected the Information Security Policy clause defining rotation cadence.	NE

A1 — Availability

Control ID	Control Description	Test Performed	Result
BC-01	A Business Continuity & Disaster Recovery Policy is maintained and reviewed annually.	Inspected BC/DR Policy v2.4, Nov 2024. Confirmed annual review attestation.	NE
BC-02	An annual disaster-recovery test is performed, including full cut-over to the secondary site, and results reported to the Management Risk Committee.	Inspected DR-test plan and results for the test performed 12–13 October 2024 (prior to the Reporting Period). Inspected Management Risk Committee minutes confirming review.	NE
BC-03	Backups are replicated cross-region and tested for restorability on a defined cadence.	Inspected AWS Backup configuration; inspected restore-test records for weekly sample restores and quarterly full-restore tests performed during the Reporting Period.	NE

C1 — Confidentiality

Control ID	Control Description	Test Performed	Result
CO-01	Customer data is identified, classified and handled in accordance with the Data Classification Standard.	Inspected the Data Classification Standard; tested a sample of 15 data-handling events for correct classification tags.	NE

Control ID	Control Description	Test Performed	Result
CO-02	Customer data transmitted to the immutable archive is encrypted prior to transmission and protected during storage.	Inspected archive pipeline configuration, encryption at transmission, and the immutable-storage lifecycle policy. Inspected access logs for the Reporting Period and confirmed access was dual-authorised.	NE

— End of Section IV —